

Web and Database Attacks

CHAPTER 5

5.01 -

Episode title: **Application Exploits, Part 1**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

APPLICATION-BASED EXPLOITS

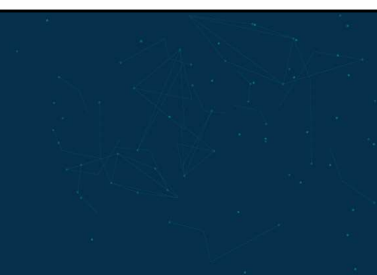
- **Injection attack**

- Inserting additional data into application beyond what is expected
- Structured Query Language (SQL)
 - Adding specially crafted SQL input to extract/modify data or execute commands
- HTML
 - Adding HTML code/submitting data to change how a page works or the data is handled

APPLICATION-BASED EXPLOITS

- **Injection attack**

- Command
 - Adding command line options that change the way commands operate
- Code
 - A generalization of SQL injection – adding code in any language to change a program's behavior



5.02 – SQL Injection Demo

Episode **SQL Injection Demo**
title:

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

SQL Injection Demo

- **SQL Injection demo**

5.03 – Labtainers Lab (SQL Injection)

Episode title: **Labtainers Lab (SQL Injection)**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

5.04 - Application Exploits, Part 2

Episode title: **Application Exploits, Part 2**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

AUTHENTICATION EXPLOITS

- **Credential brute forcing**

- Offline cracking (Hydra)

- **Session hijacking**

- Intercepting and using a session token (generally) to take over a valid distributed (web) session

- **Redirect**

- Sending the user to a different site from what they expected (phishing)

AUTHENTICATION EXPLOITS

- **Default credentials**

- Out of the box artifacts (you have to clean these up!)

- **Weak credentials**

- This is why password cracking works

- **Kerberos exploits**

- Forged tickets to allow unauthorized access to resources

AUTHORIZATION

- **Parameter pollution**

- Providing custom input parameters to alter service/API operation

- **Insecure direct object reference**

- Programming mistake that can allow an attacker to bypass access controls and access resources or data

5.05 - Application Exploits, Part 3

Episode title: **Application Exploits, Part 3**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

CROSS-SITE SCRIPTING (XSS)

- **An attacker sends malicious code (client-side script) to a web application that a subsequent client runs**

- Stored/persistent
 - Attack data (script) stored discretely on the server
- Reflected
 - Non-persistent attack in which attack code is sent to another client
- Document Object Model (DOM)
 - XSS attack that uses XML, not HTML, to transport attack code

CROSS-SITE REQUEST FORGERY (CSRF/XSRF)

- **Similar to XSS**
 - Occurs within an authenticated session
- **XSRF attacks a user**
- **Attacker can cause authorized user to take some action by clicking a link**

CLICKJACKING

- **Tricking user into clicking a different link or object that was intended**
- **Attackers can use transparent or opaque layers to embed attack links**

SECURITY MISCONFIGURATION

- **Directory traversal**

- Allows users to navigate outside a web server's root directory

- **Cookie manipulation**

- Access to cookies can allow an attacker to change the way in which a web application operates in general, or just for a specific user/session

FILE INCLUSION

- Related to directory traversal
- Attacker is allowed to build path to .exe file or a file to access
- File can be local or remote

5.06 – Cross-Site Scripting Demo

Episode title: **Cross-Site Scripting Demo**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

Demo

- **3.12 Cross-Site Scripting**

5.07 – Labtainers Lab (Cross-Site Scripting)

Episode title: **Labtainers Lab (Cross-Site Scripting)**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

5.08 – Labtainers Lab (Cross-Site Request Forgery)

Episode title: **Labtainers Lab (Cross-Site Request Forgery)**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

5.09 – API Attacks and Attack Resources

Episode title: **API Attacks and Attack Resources**

Objective: **3.3 Given a scenario, research attack vectors and perform application-based attacks**

API ATTACKS

- **Representational State Transfer (RESTful)**

- Architectural style for distributed applications using HTTP
- Based on HTTP verbs – simple and lightweight
- Popular in mobile apps

API ATTACKS

- **Extensible Markup Language Remote Procedure Call (XML-RPC)**

- XML used to encode remote procedure calls, transported via HTTP

API ATTACKS

- **Simple Object Access Protocol (SOAP)**
 - Older, more structured distributed service call architecture
 - Uses payload and envelope

ATTACK RESOURCES

- **Word lists**

- Lists of commonly use authentication credentials
- Cracking utilities use these to carry out brute-force attacks
- Some tools include common word lists
 - Kali
 - Metasploit framework
 - IKEForce
- Resources for word lists
 - Wordlistctl
 - <https://github.com/BlackArch/wordlistctl>
 - WirelessHack.org
 - <https://www.wirelesshack.org/wpa-wpa2-word-list-dictionaries.html>

5.10 Privilege Escalation (Linux)

Episode
title:

Objective:

LINUX-SPECIFIC PRIVILEGE ESCALATION

- **Set User ID (SUID) program**
- **Set Group ID (SGID) program**
 - Permission to execute a program as executable's owner/group
 - `ls -l` shows 's' in executable list of permissions
 - `-r-sr-sr-x` (SUID and SGID) set

LINUX-SPECIFIC PRIVILEGE ESCALATION

- **Superuser Do (SUDO)**
- **Unsecure SUDO**
 - Authorized users execute commands as if logged in a root

LINUX-SPECIFIC PRIVILEGE ESCALATION

- **Ret2libc**
 - Stack overflow attack
 - Replaces current stack return address with attacker-chosen address of another subroutine
 - Libc includes useful calls, such as 'system'

LINUX-SPECIFIC PRIVILEGE ESCALATION

- **Sticky bits**
 - Directory permission
 - Multiple users can create, read, and write files, but only the owner can delete
 - ls shows 't' in the last bit of permissions
 - drwxrwxrwt



5.11 Privilege Escalation (Windows)

Episode
title:

Objective:

WINDOWS-SPECIFIC PRIVILEGE ESCALATION

- **Cpassword – Group Policy Preference attribute that contains passwords**
 - SYSVOL folder of the Domain Controller (encrypted XML)
- **Clear text credentials in Lightweight Directory Access Protocol (LDAP)**

WINDOWS-SPECIFIC PRIVILEGE ESCALATION

- **Kerberoasting – domain users can query Kerberos tickets for other users**
 - <https://www.harmj0y.net/blog/powershell/kerberoasting-without-mimikatz/>
- **Credentials in Local Security Authority Subsystem Service (LSASS)**
 - Enforces security policy

WINDOWS-SPECIFIC PRIVILEGE ESCALATION

- **Unattended installation**
 - Preboot Execution Environment (PXE) credentials
- **Security Account Manager (SAM)**
- **Database SAM**
 - Database that contains user passwords
- **Dynamic Link Library (DLL) hijacking**
 - Forcing a loader to load a malicious DLL

5.12 MISC PRIVILEGE ESCALATION

Episode title: **MISC PRIVILEGE ESCALATION**

Objective:

EXPLOITABLE SERVICES

- **Unsecure service and protocol configurations**
 - Cleartext, legacy options, old protocols, default configuration
- **Unquoted service paths**
 - Allow abbreviated attack paths (without spaces)
- **Writable services**
 - Allow attacker to replace services with malicious programs

PRIVILEGE ESCALATION

- **Unsecure file/folder permissions – root installs allow read/write by any user**
- **Keylogger**
 - Records every keystroke
- **Scheduled tasks**
 - Attacker may add new task to run persistently with elevated privileges
- **Kernel exploits**
 - Unpatched systems are vulnerable

5.13

Episode title: **MISC LOCAL HOST
VULNERABILITIES**

Objective:

LOCAL HOST VULNERABILITIES

- **Default account settings – disable accounts that are not being used**
- **Sandbox escape**
 - Shell upgrade – gaining access to a shell with higher privilege
 - VM – escaping a VM may allow access to underlying environment
 - Container – similar to VM escape (i.e. Docker)

PHYSICAL DEVICE SECURITY

- **Cold boot attack**

- Ability to physically reboot a system (can allow access to encryption keys)

- **Joint Test Action Group (JTAG) debug**

- Can allow attacker to interact with chips

- **Serial console**

- If not disabled, provides direct access to servers

NEW Episode!

5.14

Episode title: **Additional Local Host Vulnerabilities**

Objective: **4.4.1.8, 4.4.2.2, 4.4.2.3, 4.4.2.4, 4.4.2.6, 4.4.2.7**

WINDOWS TOOLS

- Rubios
- Certify
- Seat Belt
- PS Exec
- Evil Win RM

RUBIUS

- Kerberos abuse
- Request, inject tickets
- Kerberoasting
- Golden, Silver tickets
- Excels in lateral movement and privilege escalation

CERTIFY

- **AD Certificate Services**
- **Identifies misconfigured certificate templates**
- **Helps exploit vulnerabilities**
 - ESC 1-8

SEAT BELT

- **Windows enumeration tool**
 - Post-exploitation reconnaissance
- **Data collection**
 - Processes
 - Installed software
 - Network configuration
 - User sessions
- **Part of the Ghost Pack suite**

PS EXEC

- Remote admin tool for MS Sysinternals Suite
- Executes commands / launches interactive shells
- Used for lateral movement
 - Upon successful admin access

EVIL WIN RM

- **Ruby-based tool**
- **Provides remote PowerShell access over WIN RM**
- **Supports:**
 - Command execution
 - File transfer
 - Script uploads